1. Introduktion

Denna studie analyserar säkerheten i vattenreningsverk, något som i Sverige är en kritisk tillgång för vårt samhälle. Vattenreningsverkets uppgift är att producera rent och säkert vatten till svenska invånare genom att mäta och reglera vattenkvalitet, kemikalier och att styra pumpar. Avbrott vid ett vattenreningsverk kan ha katastrofala påföljder, brist på rent vatten, förorenat dricksvatten, störningar i livsmedelsproduktion med flera.

Studiens syfte är att identifiera sårbarheter, hotvektorer samt att ge förslag på säkerhetsåtgärder.

1.1 Historisk attack: Oldsmar, Florida 2021

För att kunna förstå allvaret i de hot som analyseras är det viktigt att titta på verkliga händelser. År 2021 utsattes ett vattenreningsverk i Oldsmar, Florida, för en attack. En angripare lyckades genom fjärråtkomst – TeamViewer, ta kontroll över en operatörs dator.

När angriparen var inne i systemet så manipulerades halterna av natriumhydroxid (lut) från 100 ppm till 11100 ppm, vilket är en livsfarlig nivå. Tur nog upptäcktes detta i realtid av en operatör som såg muspekaren röra sig på skärmen, men händelsen visade kritiska sårbarheter i hur OT-system exponeras mot internet. Denna händelse kommer att agera som en röd tråd för denna analys för att visa på vikten av segmentering och säker fjärråtkomst.

Viktigt att notera om Oldsmar-fallet är att efter FBIs utredning framkom det uppgifter som ifrågasatte ifall det verkligen rörde sig om en extern cyberattack. Utredarna kunde inte hitta någon teknisk bevisning på att systemet blivit uttsatt för en cyberattack, teorier har lagts fram om att händelsen kan ha berott på ett mänskligt misstag av en anställd som råkat ändra värdena – se mer CyberScoop

Trots osäkerheterna kring fallet är händelsen fortfarande högst relevant. Oavsett om ändringen berodde på en extern aktör eller ett internt misstag, visades en kritisk sårbarhet. En operatördator utan korrekt segmentering eller kontroll med fjärråtkomst har förmågan att manipulera livsviktiga kemikalienivåer. Detta illustrerar att säkerhetsbrister i OT-miljöer är lika farliga oavsett om de utnyttjas av externa aktörer eller sker på grund av bristande rutiner.

2. Relevanta förkortningar och begrepp

När man talar om energianläggningar eller kraftanläggningar är det viktigt att förstå skillnaden mellan vanliga IT-begrepp och begrepp som används i industriella miljöer.

OT – Operational Technology
Till skillnad från IT (Information Technology) som hanterar data så fokuserar **OT** på att styra och övervaka fysiska processer (vattenpumpar, sensorer, kemikaliedosering).

ICS – Industrial Control Systems
ICS är ett samlingsnman för de system som används för att kontrollera industriella processer, så som:

- **SCADA (Supervisory Control and Data Acquisition)** är det system som operatörer använder för att övervaka vattenverket från kontrollrummet.
- **PLC (Programmable Logic Controller)** är i detta fall “små datorer” som är kopplade till pumpar som med hjälp av logik (om vattennivån är låg, starta pumpen) styr dem.
- **HMI (Human Machine Interface)** är skärmar där operatörer kan se och ändra relevanta värden.
- **DMZ (Demilitariserad zon)** är en nätverkssegmenterad buffertzon som separerar IT-nätverk från OT-nätverk. DMZ används för att begränsa kommunikation mellan internet/IT och känsliga system.

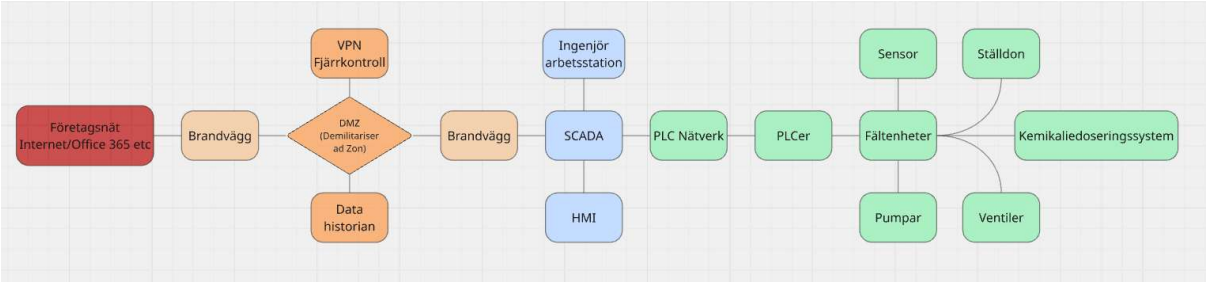
Skillnad mellan IT och OT
Ett vanligt misstag är att man tror att IT-skydd räcker när det gäller OT. Ofta när det kommer till IT säkerhet skyddar man information, men i vattenkraftverk (OT) skyddar man själva processen, ändring av pH värde, pumphastighet osv. Ett bra begrepp som man kan använda är Safety vs Security, i IT-miljö vill man skydda från att data läcker medans i OT vill skydda systemets integritet, det som påverkar den fysiska säkerheten.

3. System beskrivning

Anläggningens huvudsyfte är att omvandla råvatten till säkert dricksvatten genom en serie av processer, filtrering, kemisk rening och dosering samt distribution.

3.1 Nätverksarkitektur och logisk uppbyggnad

Som det bifogade Miro-schemat visar är systemet uppbyggt enligt Purdue-modellen för att separera den administrativa IT-miljön från den operativa OT-miljön. Schemat är indelat i fem logiska zoner:



- **Nivå 5 & 4 (Enterprise röd zon):** Här finns verkshamhetens kontorsnät med internetanslutning. Ingen direkt styrning av vattenreningsverket tillåts härifrån.
- **Nivå 3.5 (DMZ – demilitariserad zon, orange zon):** Detta fungerar som en säkerhetssluss med brandväggar före och efter. I DMZ finner man en VPN-gateway för säker fjärrstyrning och en Data Historian som speglar driftdata för analys utan att exponera styrsystemet direkt mot internet.
- **Nivå 3 (Operations blå zon):** Kontrollrumsnivå där SCADA-servern agerar centralt. Här finns även HMI för övervakning samt ingenjörsarbetsstation (Engineering Workstation) för systemkonfiguration.
- **Nivå 2 (Control grön zon):** Här sker den logiska styrningen genom PLC:er. De körs automatiskt, exempelvis när en pump ska starta beroende på värden som skickas av en sensor.
- **Nivå 1-0 (Field grön zon):** Detta är den fysiska processnivån med sensorer (pH-mätare, flödesgivare) och ställdon (ventiler, motorer och pumpar)

3.2 Processflöde och kommunikation

Systemet fungerar genom att sensorer på fältnivå skickar signaler till PLC-enheterna, som bearbetar data och i sin tur skickar instruktioner till ställdon (t.ex. öppna ventil för klortillsats).

All denna data skickas upp till SCADA-servern på nivå 3, vilket gör det möjligt för en operatör att genom HMI få en överblick av vattenreningsverket. Kommunikationen mellan nivå 2 och 3 sker via industriella protokoll (Modbus TCP eller PROFINET) som ställer krav på säkerhet då dessa protokoll ofta saknar inbyggd kryptering.

4. Identifiering av kritiska tillgångar

I ett vattenreningsverk handlar allt om att skydda själva processens integritet, dvs. Safety vs Security. Om data ändras utan att man lägger märke till det, kan det leda till extrema konsekvenser. De viktigaste tillgångarna är följande:

1. **PLC för kemikaliedosering**
   Detta är den mest kritiska komponenten (Grön Zon i Miro-schemat). Den gör precis vad namnet säger – styr mängden kemikalier som tillsätts i vattnet.
   - Det som kan hända ifall denna PLC kompromissas är att en angripare kan ändra logiken så att livsfarliga mängder kemikalier släpps ut i vattnet. Det värsta scenariot hade varit ifall en angripare fryser värdena i SCADA-systemet så att operatören inte ser någon skillnad, så kallad False Data Injection.
   - Konsekvensen är därav kritisk eftersom den kan innebära en direkt livsfara för konsumenter.
2. **SCADA server**
   Hjärnan i kontrollrummet (Blå Zon i Miro-schemat) samlar in data från alla PLC:er och arkiverar den.
   - En kompromissering av SCADA-servern kan innebära att operatörerna blir “blinda”; de kan till exempel inte se om en pump har slutat fungera eller om en bassäng svämmar över. SCADA-servern kan även bli utsatt för ransomware-attacker (t.ex. LockBit) och då stannar hela den administrativa styrningen.
   - Beroende på hur systemet blir komprimerat är konsekvensen kritisk-hög. Kraftverket kan behöva tas ur drift eller gå över till manuell drift, vilket är riskfyllt och personalkrävande.
3. **Engineering Workstation**
   Datorn som används för att konfigurera, uppdatera och ladda upp kod till PLC:erna (Blå Zon i Miro-schemnat)
   - Om denna komponent kompromissas betyder det att en angripare i princip har nycklarna till kungariket. Hela anläggningens beteende kan då ändras, precis som hände i Stuxnet-attacken – enligt Kushner David i The Real Story of Stuxnet användes fyra zero-day exploits på Windows-maskiner, som sedan sökte ut Siemens Step 7-mjukvara för att genomföra attacken.
   - Precis som i Stuxnet-attacken är konsekvenserna här kritiska då en ändring i PLC-kod är väldigt svårt att upptäcka utan en fysisk inspektion.
4. **Fältenheter, sensorer för pH**
   Systemets ”ögon” används för att bland annat se vattenkvalitet.
   - Kompromissering av dessa kan innebära att sensorerna skickar falska värden, t.ex. pH-värdet är för lågt. Då kommer PLC:n automatiskt att börja dosera mer för att höja pH-värdet.

5. Identifiera attackytor

Attackytan är alla punkter där en obehörig kan försöka kommunicera med eller påverka systemet. Med hjälp av Miro-schemat kan vi identifera följande ytor:

1. Den externa fjärråtkomsten (VPN-Gateway i DMZ)
    - Den största attackytan ligger här. Om det används svaga lösenord eller om MFA saknas, kan detta vara en angripares första väg in.
    - I ICS-miljöer är fjärråtkomst ofta nödvändig för leverantörer. Detta skapar då en tredjepartsrisk – om leverantören blir utsatt för hack kan det bli en tunnel in i vattenreningsverket.
2. HMI & Arbetsstationer
    - Terminaler i kontrollrummet kan också leda till fysiska attacker, USB-portar (t.ex. laddning av mobiltelefoner, filöverföring), samt webbläsare på operatördatorer som kan användas för att råka ladda ner skadlig kod.
3. Protokollsårbarheter (Nivå 2-3)
    - Kommunikationen mellan SCADA och PLC. Många äldre industriprotokoll (t.ex. Modbus) saknar kryptering och autentisering. Om en angripare tagit sig in i systemet kan hen då avlyssna trafiken eller skicka falska kommandon direkt till PLC utan autentisering.
4. Fysisk tillgång (Fältenheter)
    - Sensorer, pumpar m.fl. Som sitter vid skymda platser kan vara utsatta för fysiska angrepp. En angripare kan koppla upp sig i en nätverkskabel vid ett sådant ställe och potentiellt nå hela vägen upp till SCADA om nätverket inte är korrekt segmenterat.

6. Identifiera hot och Kill Chain

Här kopplar vi attackytorna till specifika hotaktörer och deras intressen. Samt går igenom attackvektorer, även kallade kill chain.

6.1 Hotbild

Ett vattenreningsverk är samhällskritiskt och man ser på ett vattenreningsverk ur ett angriparperspektiv så blir det attraktivt av flera olika skäl, beroende på vem hotaktören är. Jag kommer nedan gå igenom några av dessa hotaktörer och vad deras mål är.

6.2 Hotaktörer

Länder är de med sofistikerade hotaktörer som har tillgång till mest resurser. Fokus ligger på spionage eller positionering för framtida sabotage. **CISA** och **FBI** har utfärdat olika varningar gällande statliga aktörers intresse för Water and Wastewater Systems – Environmental Protection Agency.

Cyberkriminellas motiv ligger tillskillnad från statliga aktörers informations motiv, ofta vid ekonomisk vinning, därför använder cyberkriminella ofta sig utav Ransomware – Veolia North America, som 2024 hotades av driftstopp om inte lösensumma betalades.

Hacktivister är ofta motiverade av ideologi, och har som syfte att bilda opinion eller skapa oro i samhället. Exempel på några sådana här grupper är Cyber Army of Russia Reborn, Z-Pentest, NoName057 och Sector16 som enligt CISA uttfört OT-attacker i USA och Ukraina.

Insiders är nuvarande eller tidigare anställda med behörighet. Ett fall som är relevant är **Post Rock Water District**, **Kansas** (2019) där en tidigare anställd utnyttjade aktiva inloggningsuppgifter för att enligt Water Isac manipulera reningssystemet.

6.3 Systemspecifika sårbarheter

Vattenreningsverkets specifika egenskaper skapar sina egna risker:

1. **Protokoll utan autentisering**: Användning av **Modbus TCP** innebär att kommunikation saknar kryptering – en angripare kan skicka kommandon direkt till en PLC.
2. **Fysisk påverkan**: Till skillnad från många IT-system så leder manipulation av kemisk dosering till fysiska hälsoföljder hos konsumenter.
3. **Exponerad fjärråtkomst**: Behovet av konstant övervakning med begränsad personal gör fjärråtkomst till en nödvändighet, vilket i sig skapar en digital attackyta.
4. **Resursbrist**: Begränsad kompetens inom IT/OT inom kommunal verksamhet ökar risken för standardlösenord och bristande logguppföljning.

6.4 Attack analys (Kill chain)

6.4.1 Refferensattack: Oldsmar 2021

Som det beskrivits i intoduktionen av denna analys riktades en attack mot Oldsmar Water Treatment Plant i februari 2021. Angriparen använde sig av ett fjärrstyrsverktyg (TeamViewer) som var installerat på en operatörsdator, för att ta kontroll och höja natriumhydroxid (lut) halten från 100 ppm till 11100 ppm. Attacken lyckades stoppas av en vaksam operatör.

Det som gör Oldsmar intressant i denna analys är inte bara vad som hände utan vad som avslöjades kring systemets arkitektur.

- TeamViewer var installerat utan authentisering (MFA)
- Operatörsdatorn hade direkt åtkomst till kemikaliedoseringssystemet
- Det saknades automatiska larm för avvikande värden

FBIs efterföljande utredning kunde visserligen inte fastställa att någon extern aktör låg bakom attacken, men det förändrar inte att systemets utforming faktiskt gjorde ett sådant scenario möjligt, oavsett om det handlade om ett misstag eller inte.

6.4.2 Kill chain – Vattenreningsverk

Nedan kommer en attackkedja mot ett modernt vattenreningsverk att beskrivas, baserat på kända tekniker och dokumenterade fall. Kedjan är uppbyggd enligt MITRE ATT&CK för ICS-ramverket.

STEG 1 – Kartläggning
Angriparen kartlägger vattenverkets exponerade tjänster via Shodan eller Censys. Identiferar öppen RDP/VPN port, leverantörens namn (jobbannonser eller annat) och Mjukvaruversion.

STEG 2 – Första åtkomst
Phishing (mer specifikt spear-phishing) mot en operatör eller leverantör. Alternativt brute force mot VPN gateway med svagt/standardlösenord utan MFA
(Oldsmar: TeamViewer utan MFA)

STEG 3 – Etablering i IT-nätverket
Angriparen kan installera RAT (Remote Access Trojan) eller använda legitima verktyg för att undvika att bli påkommen. Kartlägger nätverket inifrån.

STEG 4 – Lateral movement mot OT
Angriparen rör sig från IT-nätverket mot nästa zon (DMZ).
Utnyttjar felkonfigurerade brandväggar eller svag segmentering, för at hitta vägen till Engineering Workstation eller SCADA-servern.

STEG 5 – Kartläggning i OT miljön
Avlyssnar Modbus TCP-trafik för att få en förståelse av PLC-logiken. Identifiera vilka register som styr kemikaliedosering. (Modbus saknar autentisering – trafiken är läsbar)

STEG 6 – Manipulation
Skickar falska Modbus-kommandon direkt till PLC för kemikaliedosering. Smatidigt injicerars falska sensorvärden i SCADA (False Data Injection) så att operatören ser normala värden på sinHMI.

STEG 7 – Konsekvens
Farliga kemikalier når ut i vattnet– livsfara. Alternativt att ransomware aktiveras på SCADA-servern och verksamheten tvingas övergå till manuell drift eller betala utpressningssumman.

6.4.3 MITRE ATT&CK

MITRE ATT&CK		
Fas	Teknik	ID
Initial åtkomst	Spear Phishing / Remote Services	T0865 / T0886
Lateral movement	Default Credentials	T0812
Exekvering i OT	Modify Parameter	T0836
Undvik Detektion	Spoof Reporting Message (False Data Injection)	T0856
Påverkan	Manipulation of Control	T0831

7. Risk analys

Hoten bedöms utifrån sannolikhet och konsekvens och kombineras till ett riskvärde. Motiveringarna kommer att fokusera på det som är specifikt för ett vattenreningsverk.

7.1 Riskmatris

Riskmatris				
Nr	Hot	Sannolikhet	Konsekvens	Riskvärde
1	Ransomware mot SCADA-server	Hög	Hög	Kritisk
2	PLC manipulation via Modbus	Medium	Kritisk	Kritisk
3	False Data Injection	Medium	Kritisk	Kritisk
4	Intrång via fjärråtkomst utan MFA	Hög	Hög	Kritisk
5	Lateral movement IT→OT	Medium	Hög	Hög
6	Insider attack via kvarlämnat konto	Medium	Hög	Hög
7	Spear-phishing mot operatör	Hög	Medium	Hög
8	Fysisk manipulation av fältenhet	Låg	Hög	Medium

7.2 Motivering av kritiska risker

PLC manipulation och False Data injection (2&3)
Dessa två hot är farligast i kombination med varandra. Modbus saknar autentisering, vilket innebär att en angripare som nått OT segmentet kan manipulera kemikaliedosering samtidigt som man skickar falska sensorvärden till HMI – Operatören ser normala värden, medan doseringen stiger till farliga värden. Denna sårbarhet illustreras i Oldsmar fallet.

Fjärråtkomst utan MFA (4)
Sannolikheten är hög eftersom CISA identiferar i sin rådgivnings rapport "Ongoing Cyber Threats to U.S Water and Wastewater Systems" att vattenreningsverk är ovanligt sårbara, med liten IT personal, oftast ingen dedikerad säkerhetspersonal, åldrande SCADA-system och fjärråtkomst utan tillräcklig säkerhet (MFA). Åter igen ser vi på Oldsmar fallet att anläggningen saknade MFA, delade ett endalösenord för alla fjärråtkomstkonton och hade ingen nätverkssegmentering mellan IT och OT.

Ransomware (1)
Cyberkriminella grupper riktar sig ofta aktivt mot kommunal och statlig infrastruktur. Kräver inte OT kunskap utan det räcker att man når SCADA servern från IT sidan via **Lateral movement IT→OT (5)**.

8. Säkerhetsåtgärder

Åtgärderna är prioriterade utifrån riskanalysen och tar upp de kritiska riskerna först med högsta prioritet.

Åtgärder		
Åtgärd	Motverkar	Prioritet
MFA på alla fjärråtkomst	Nr 4	Kritisk
Nätverkssegmentering IT/OT	Nr 1, 5	Kritisk
Protokollfiltrering / OT-brandvägg	Nr 2, 3	Kritisk
Anomalidetektering i OT-trafik	Nr 2, 3	Hög
Lösenordsrotation & kontohantering	Nr 4, 6	Hög
Säkerhetsutbildning för operatörer	Nr 7	Hög
Fysisk åtkomstkontroll vid fältenheter	Nr 8	Medium

8.1 Motivering av prioterade åtgärder

MFA på all fjärråtkomst (Nr 4) Den enskilt viktigaste åtgärden. Oldsmar-fallet och CISAs rådgivning AA21-287A pekar på att brist på MFA är den primära sårbarheten. MFA eliminerar inte alla risker, men höjer svårighetsgraden mycket och är en förutsättning för övriga åtgärders effektivitet.

Nätverkssegmentering IT/OT (NR 1, 5) En korrekt uppsatt DMZ med brandväggar som tillämpar default deny förhindrar lateral movement från IT-miljö till OT-segmentet. Detta innebär att en angripare som kompromissar IT-sidan (t.ex. genom Nr 5) inte automatiskt får tillgång till SCADA-servern eller styrsystemet. Det skapar även ett skydd där ransomware enbart kan komma åt IT-miljön och därav skyddar SCADA-servern från direktexponering. Purdue-modellen som beskrivs i nätverksarkitekturen fungerar som en referensram för hur segmenteringen bör konstrueras.

Protokollfiltrering och OT-brandvägg (Nr 2, 3) Eftersom Modbus TCP saknar inbyggd autentisering måste skyddet läggas på nätverksnivå. En OT-specifik brandvägg (t.ex Cisco Secure Firewall, Sheildworkz, Palo, Claroty) kan inspektera och filtrera Modbus-kommandon, blockera och larma vid avvikelser.

Anomalidetektering i OT-trafik (Nr 2, 3) Passiv nätverksövervakning som har en baslinje för vad normal PLC-kommunikation är och larmar vid avvikelser. Detta är det primära försvaret mot False Data Injection, eftersom sådana attacker annars inte syns i vanliga IT-säkerhetsystem. Detta är det närmaste man kommer till ett skydd mot nr 3-scenariot där operatören aktivt vilseleds.

9. Utvärdering

9.1 Styrkor i rekommenderat försvar

Det försvar som rekommenderats bygger på principen om ***Defense in depth*** – flera lager som kompenserar för varandras svagheter. MFA eliminerar den vanligaste attackvektorn, segmentering begränsar skadan och anomalidetektering tar hand om det farligaste scenariot där en operatör aktivt vilseleds.

9.2 Kvarstående risker

Inget försvar är helt komplett. Tre risker är särskilt svåra att eliminera:

False Data Injection (Nr 3) Förblir det svåraste hotet att stoppa, anomalidetektering hjälper, men en kunnig angripare som förstår systemet kan injicera falska värden som ligger inom de normala gränsvärden – tillräckligt för att undvika larm men tillräckligt avvikande för att orsaka skada över tid.

Supply chain attacker är det närmast omöjligt att skydda sig mot på anläggningar. Om en leverantör av PLC-mjukvara eller SCADA-mjukvara kompromissar så introduceras sårbarheter innan säkerhetskontrollerna ens aktiveras. Detta kan vi se på SolarWinds-attacken (2020) som dokumenterats väl av Fortinet – även välsäkrade miljöer är sårbara mot denna attackvektor.

Den mänskliga faktorn kvarstår som en sårbarhet. Säkerhetsutbildning reducerar risken för phishing men eliminerar inte den. I kommunala verksamheter med hög personalomsättning och begränsade resurser är det inte möjligt att förvänta sig samma säkerhetsmedvetenhet som i större organisationer med fler resurser.

9.3 Kritisk reflektion

En viktig slutsats man kan dra från denna analys är att det tekniska försvaret ofta är enklare att åtgärda än de organisatoriska bristerna. MFA, segmentering och OT-brandväggar är kända lösningar, men ändå saknas de i stor utsträckning i kommunal vatteninfrastruktur. CISAs rådgivningsrapport pekar på resursbrist och kompetensbrist som grundorsaker, inte teknisk sammansättning.

Detta pekar på att den viktigaste säkerhetsåtgärden inte ligger på systemnivå utan på organisatorisk nivå. Sverige har visserligen lagstiftning som reglerar vattenkvalite och infrastruktur – bland annat Lag (2006:412) om allmänna vattentjänster (LAV) och Livsmedelsverkets föreskrifter om dricksvatten. Men dessa fokuserar på vattenkvalitet och miljöskydd snarare än cybersäkerhet i OT-miljöer. Det saknas därför lagstiftning för nationella minimikrav på OT-säkerhet för kommunala vattenreningsverk liknande det amerikanska AWIA (America's Water Infrastructure Act) från 2018 som kräver regelbundna cybersäkerhetsriskbedömningar av vattenreningsverk. Detta är en strukturell sårbarhet som ingen brandvägg kan kompensera för.